



ЖИЗНЕННЫЙ ЦИКЛ ИБ

ПРАКТИЧЕСКОЕ ЗАДАНИЕ: План реагирования на инциденты для ООО «АВС»

Выполнил: Юрий Шамрай (MIFIB/1-й поток)

ДАННЫЕ О КОМПАНИИ:

- Компания ООО «АВС» (далее Компания) - финансовая организация;
- Руководитель – председатель правления Иванов А. Г.;
- Начальник отдела информационной безопасности – Петров Б. В.;
- У Компании есть собственная SIEM-система управления событиями безопасности;
- В ООО «АВС» уже разработана политика управления инцидентами информационной безопасности (ИБ). Она ссылается на отдельный низкоуровневый детализированный документ «План реагирования на инциденты ИБ».

УСЛОВИЕ ПРАКТИЧЕСКОГО ЗАДАНИЯ:

- Напишите план реагирования на инциденты ИБ для ООО «АВС»;
- В плане опишите порядок реагирования в общих случаях и, например, в виде отдельных порядков опишите реагирование на конкретные виды инцидентов, включая план реагирования на выявление вредоносного ПО;
- План реагирования должен отвечать на следующие вопросы:
 - ✓ Что делать в общем случае при выявлении инцидента?
 - ✓ Что делать при выявлении конкретного инцидента: вредоносное ПО на серверах компании?
 - ✓ Кто или что может выявить инцидент в компании;
 - ✓ Кого должен уведомить этот сотрудник или система;
 - ✓ Что должен сделать ответственный за дальнейшие действия сотрудник;
 - ✓ Кто в каких случаях включается в рабочую группу;
- План реагирования может включать общую часть, верную для любой ситуации. Также в него могут входить отдельные планы для конкретных распространённых ситуаций: DDoS-атак, выявления ВПО, утечки персональных данных, аномальной активности административной учетной записи и т. д.

УСЛОВИЯ РЕАЛИЗАЦИИ:

- Пришлите письменный отчёт в формате документа Microsoft Word или в формате PDF;

ДЕТАЛЬНЫЙ АНАЛИЗ ВВОДНЫХ ДАННЫХ О КОМПАНИИ

Данные о Компании:

1. Компания ООО «АВС» - финансовая организация
Которая занимается предоставлением финансовых услуг, включая банковские операции, инвестиции или страхование. Учитывая характер и конфиденциальность финансовых данных, защита информации и обеспечение безопасности являются критически важными аспектами для этой организации.
2. Должность председателя правления Компании занимает её руководитель - Иванов А. Г.
Он является ответственным за обеспечение общего направления и поддержку политик безопасности в организации.
3. Руководитель отдела информационной безопасности - Петров Б. В.
Компания придает большое значение защите своих информационных активов и реагированию на угрозы безопасности. Поэтому был создан специальный отдел по информационной безопасности, который отвечает за разработку и реализацию политик, процедур, а также технических мер ИБ в Компании.
4. [SIEM \(Security Information and Event Management\)](#)
Компания внедряет технологические средства для активного мониторинга и обладает собственной SIEM-системой управления событиями ИБ. Что позволяет ей централизованно собирать и анализировать данные о безопасности из различных источников в реальном времени, обнаруживать потенциальные угрозы и эффективно реагировать на них.
5. Компания уже разработала Политику Управления Инцидентами ИБ, которая определяет общие стратегии и принципы, а также, охватывает некоторые аспекты управления инцидентами, включая проактивные меры, процедуры обнаружения, классификацию и приоритетность инцидентов, коммуникацию, координацию и контроль, устанавливает роли, ответственности и обязанности различных заинтересованных сторон внутри Компании.
6. Политика Управления Инцидентами ИБ является основой для разработки более конкретных процедур, поэтому она ссылается на отдельный низкоуровневый детализированный документ «План реагирования на инциденты ИБ». Он конкретизирует действия (инструкции), ресурсы и ответственности, которые должны быть предприняты в случае возникновения инцидента безопасности. Т. е. является более оперативным руководством, которое служит основой для действий персонала при возникновении конкретного инцидента безопасности.

Все полученные данные о Компании ООО «АВС» позволяют предположить, что она серьезно относится к вопросам информационной безопасности и имеет ресурсы для поддержания высокого уровня безопасности своей деятельности. Такие меры способствуют укреплению доверия клиентов и партнёров Компании, а также, соблюдению требований отраслевых стандартов и нормативных актов.

ПОСТРОЕНИЕ ЭФФЕКТИВНОЙ СТРАТЕГИИ РАБОТЫ С ИНЦИДЕНТАМИ

Далее, постараемся подробно рассмотреть основные этапы жизненного цикла управления инцидентами, применительно к условию нашего практического задания.

Подготовка:

Целью этапа подготовки является минимизация негативных последствий инцидентов ИБ для Компании. Заранее разработанные планы реагирования позволяют оперативно принимать меры по ликвидации уязвимостей, защите активов и восстановлению нормального функционирования систем и процессов.

1. Создание инфраструктуры:
 - Настроить правила журналирования событий на всех устройствах в инфраструктуре Компании;
 - Внедрить SIEM-систему для анализа логов и оперативного выявления любых подозрительных событий.

2. Обучение сотрудников:

- Провести обучение сотрудников по предотвращению инцидентов ИБ, осведомленности о социальной инженерии, безопасному поведению в Интернете и процедурам реагирования на инциденты;
- Включить информацию на основе прошлых инцидентов и лучших практик в обучающие материалы.

3. Разработка плана реагирования на инциденты ИБ (playbook):

- Написать план реагирования для общих случаев, описывающий порядок действий при выявлении инцидента ИБ;
- Составить дополнительный план реагирования на конкретные виды инцидентов, таких как DDoS-атаки, утечки персональных данных и аномальная активность административных учетных записей, а также, в случае выявления вредоносного ПО на серверах Компании.

4. Идентификация ответственных лиц и контактных данных:

- Определить ответственных сотрудников, которые будут отвечать за обработку инцидентов ИБ и реализацию плана реагирования;
- Создать список контактных данных ответственных лиц и их ролей для быстрого уведомления и сотрудничества при инцидентах.

В целом, этап подготовки позволяет Компании создать основу для эффективного управления инцидентами ИБ, минимизировать риски и последствия инцидентов, а также повысить уровень безопасности и готовности к возможным угрозам.

Обнаружение и анализ:

Целью этапа обнаружения и анализа является обеспечение своевременного обнаружения инцидентов, активный анализ событий и последующие действия по решению проблемы.

Обнаружение инцидента:

- Настроить инструменты и системы мониторинга, для непрерывного анализа событий и трафика в сети;
- При обнаружении аномалий, нарушений или подозрительных активностей система должна генерировать алерты или оповещения.

1. Оповещение ответственных лиц:

- Ответственные сотрудники (например, начальник отдела ИБ) должны быть немедленно уведомлены о возникшей ситуации;
- Уведомление может осуществляться через различные каналы связи, такие как электронная почта, мессенджеры, звонки или СМС.

2. Фиксация инцидента:

- Ответственный сотрудник должен зафиксировать информацию об инциденте в специальном журнале. Это позволит точно восстановить хронологию событий, а также обеспечит возможность проведения дальнейшего анализа и расследования.

3. Классификация и приоритизация инцидента:

- Инцидент должен быть классифицирован и определен его уровень приоритета. Это поможет в оценке критичности проблемы и срочности принимаемых решений;
- Классификация может основываться на типе инцидента, его потенциальном ущербе и влиянии на бизнес Компании.

4. Формирование рабочей группы:

- В зависимости от типа инцидента и его характеристик, ответственные сотрудники должны привлечь соответствующую рабочую группу;
- Это может включать разработчиков, системных администраторов, сетевых инженеров и других специалистов, которые будут участвовать в детальном анализе инцидента и принятии мер по его решению.

5. Уведомление руководства и регуляторов:

- В случае серьезных инцидентов, таких как утечка данных или нарушение функционирования публичного сервиса, необходимо принять решение об уведомлении руководства и, при необходимости, регуляторных органов;
- Также может потребоваться решение об уведомлении СМИ в зависимости от характера инцидента.

В целом, этап обнаружения и анализа является ключевым в управлении инцидентами информационной безопасности. Он позволяет своевременно выявлять потенциальные угрозы и нарушения, а также анализировать их для принятия соответствующих мер по предотвращению и реагированию на инциденты в будущем.

Локализация, ликвидация и восстановление:

Цель этапа локализации, ликвидации и восстановления в управлении инцидентами ИБ, заключается в эффективной и оперативной реакции на инциденты, минимизации их воздействия на системы и данные, восстановлении нормальной работы и обеспечении безопасности информационной инфраструктуры Компании.

1. Локализация инцидента:

- Быстро и точно определить масштаб инцидента, выявить задетые системы и устройства;
- Предотвратить дальнейшее распространение инцидента.

2. Ликвидация инцидента:

- Устранить причину инцидента, исправить уязвимости;
- Восстановить поврежденные или скомпрометированные системы и данные.

3. Расследование и анализ:

- Провести детальный анализ инцидента, выявить причины и способы атаки, собрать доказательства и артефакты для последующего расследования;
- Принять меры для предотвращения повторного возникновения инцидента.

4. Усиление безопасности:

- Принять меры по усилению безопасности систем и сетей Компании;
- Внедрить патчи, обновления и дополнительные меры защиты.

5. Восстановление работы системы:

- Вернуть системы и процессы Компании в нормальное состояние работы;
- Восстановить функциональность сервисов и приложений, минимизировать простой бизнес-процессов.

В целом, этот этап помогает Компании восстановиться после инцидента, укрепить свою защиту и повысить уровень безопасности информационной инфраструктуры, что является важным для обеспечения бесперебойной работы и защиты конфиденциальности, целостности и доступности данных.

Меры, принимаемые после события:

Цель этого этапа, т. е. мер, принимаемых после события, состоит в усилении безопасности Компании, минимизации последствий инцидентов и предотвращении их возникновения в будущем.

1. Оформление сводки по инциденту:

- «Post mortem» - Проводится подробная документация инцидента в виде сводки или отчета;
- Зафиксировать причины возникновения инцидента, всю хронологию событий, принятые решения, ущерб и последствия инцидента, результаты расследования и восстановления системы;
- Составить полное представление о произошедшем инциденте.

2. Обновление базы знаний и Threat Intelligence (TI):

- Наиболее критичные данные, выявленные в результате расследования инцидента, заносятся в базу знаний Компании;
- Также, эти данные могут быть добавлены в базу поставщиков TI.

3. Принятие дополнительных мер:

- На основе результатов расследования и анализа инцидента, при необходимости, принять дополнительные организационные и технические меры для улучшения информационной безопасности;
- Обновление политик безопасности, улучшение процедур аутентификации, обновление систем и приложений, повышение осведомленности сотрудников и проведение дополнительного обучения.

В целом, этот этап направлен на непрерывное совершенствование и дальнейшее улучшение информационной безопасности Компании (возврат на этап подготовки), методом постоянного обновления политик, процедур и систем, а также регулярное обучение сотрудников, чтобы они оставались в курсе актуальных угроз и мер по их предотвращению.

Мы подробно рассмотрели полученные данные о Компании, а также, детально изучили основные этапы жизненного цикла управления инцидентами, с учётом нашего полного чек-листа условий практического задания.

Далее, переходим к составлению плана реагирования на инциденты для Компании ООО «ABC».

Документ будет составлен в соответствии с применяемым внутренним стилем организации ООО «ABC».

С целью обеспечить единообразие, чёткость и эффективность документооборота внутри организации.

Он опирается на следующие принципы:

- Единообразие форматирования: Документы, созданные в соответствии с данным стилем, следуют определенным стандартам форматирования. Это включает использование установленных шрифтов, размеров и стилей, а также оформление заголовков, списков и других элементов документа.
- Простота и ясность: Внутренние документы, составленные в данном стиле, придерживаются простого и понятного языка. Они структурированы логично и последовательно, чтобы облегчить чтение и понимание информации.
- Использование внутренних терминов: в соответствии с внутренними нормами и терминологией организации, данный стиль предполагает использование специфических терминов и сокращений, понятных только внутри компании. Это облегчает обмен информацией и укрепляет внутреннюю идентичность.
- Структура документа: Данный стиль предусматривает определенную структуру для различных типов документов, таких как отчеты, протоколы, письма и т. д. Это обеспечивает последовательность и понятность внутренних коммуникаций.

Использование данного стиля составления документов внутри организации ООО «ABC» помогает повысить эффективность работы, улучшить коммуникацию и обеспечить единообразие документооборота.

Дата: [дата утверждения]

Вступает в силу: [дата вступления в силу]

Цель:

Цель данного плана состоит в обеспечении быстрого и эффективного реагирования на различные типы инцидентов, с целью минимизации потенциальных ущербов, прерывания бизнес-процессов и сохранения конфиденциальности, целостности и доступности данных. Путем определения четких процедур, ответственных лиц и рабочей группы, а также проведения обучения сотрудников, для обеспечения эффективной координации и синхронизации действий при обнаружении инцидента, а также на минимизацию времени восстановления и предотвращение повторных инцидентов в будущем.

I. Общий порядок реагирования на инциденты:

1. Выявление инцидента:

- 1.1. Инцидент может быть обнаружен сотрудниками компании, SIEM-системой или внешними источниками;
- 1.2. При обнаружении любого подозрительного или аномального поведения инцидент должен быть немедленно зафиксирован и зарегистрирован.

2. Уведомление ответственных лиц:

- 2.1. Сотрудник, который обнаружил инцидент, немедленно уведомляет ответственного за информационную безопасность (начальника отдела ИБ).

3. Оценка и классификация инцидента:

- 3.1. Ответственный за ИБ проводит первичную оценку инцидента и классифицирует его по уровню серьезности, потенциальных последствий и приоритетов, используя установленные критерии;
- 3.2. Информация о классификации инцидента должна быть подробно документирована;
- 3.3. В особо критических случаях информация об инциденте должна быть передана руководству Компании.

4. Активация рабочей группы:

- 4.1. В зависимости от классификации инцидента и его характера, назначается ответственный сотрудник или рабочая группа;
- 4.2. Работа по реагированию на инцидент проводится в соответствии с предварительно разработанными процедурами.

5. Сбор дополнительной информации:

- 5.1. Рабочая группа собирает дополнительную информацию об инциденте, включая логи и аналитические данные;
- 5.2. Любую другую доступную информацию, для более детального анализа ситуации.

6. Анализ и меры по управлению инцидентом:

- 6.1. Рабочая группа проводит анализ инцидента, определяет его причины и масштаб;
- 6.2. Разрабатывает конкретные меры по управлению инцидентом для его пресечения, устранения и предотвращения повторения.

7. Изоляция и реагирование:

- 7.1. Рабочая группа принимает меры по изоляции инцидента, например, отключая зараженные системы от сети;
- 7.2. Применяет соответствующие технические меры для остановки распространения инцидента.

8. Восстановление и очистка:

- 8.1. После изоляции инцидента проводятся мероприятия по восстановлению систем и данных;
- 8.2. Очистка от вредоносного кода или влияния инцидента.

9. Анализ и документирование инцидента:

- 9.1. Рабочая группа проводит анализ инцидента, фиксирует все детали и результаты реагирования;
- 9.2. Предлагает улучшения для будущих ситуаций.

10. Пост-инцидентный анализ и обучение:

- 10.1. Проведение пост-инцидентного анализа для выявления слабых мест в системе безопасности и предотвращения повторения инцидентов;
- 10.2. Обучение сотрудников компании, включая обновление знаний и навыков по обнаружению и реагированию на инциденты ИБ.

II. Порядок реагирования на конкретные виды инцидентов:

- 1. При выявлении вредоносного ПО на серверах компании:
 - 1.1. Инфицированные серверы должны быть немедленно изолированы от сети;
 - 1.2. Запускается процедура сканирования и удаления вредоносного ПО с зараженных серверов;
 - 1.3. Если требуется, то восстанавливаются данные с резервных копий;
 - 1.4. Анализируются причины инцидента и принимаются меры для предотвращения повторного инцидента.
- 2. При DDoS-атаке:
 - 2.1. Оповещение поставщиков услуг интернет-связи о DDoS-атаке;
 - 2.2. Запуск мер защиты от DDoS-атак на сетевом и прикладном уровне;
 - 2.3. Мониторинг и анализ сетевого трафика для выявления аномалий и принятия дополнительных мер по смягчению атаки.
- 3. При утечке персональных данных:
 - 3.1. Идентификация и остановка источника утечки данных;
 - 3.2. Оповещение руководства компании о случившемся;
 - 3.3. Установление мер для предотвращения дальнейшей утечки данных;
 - 3.4. Информирование клиентов или субъектов данных, затронутых утечкой, в соответствии с применимыми законодательными требованиями.
- 4. При аномальной активности административных учетных записей:
 - 4.1. Блокировка учетной записи, показавшей аномалию;
 - 4.2. Изучение журналов активности и аудита для выяснения причин и масштаба инцидента;
 - 4.3. Определение действий злоумышленника и выявление возможных уязвимостей в системе;
 - 4.4. Принятие мер по устранению уязвимостей и восстановлению безопасности учетных записей (изменяются пароли).

III. Рабочая группа:

- 1. Ответственный за информационную безопасность Петров Б. В.
- 2. IT-специалисты: Системный администратор, Специалист по ИБ.
- 3. Представители юридического и HR-отделов (при необходимости).

В целях эффективного реагирования на инциденты ИБ и соблюдения плана, компания должна обеспечить обучение и осведомленность сотрудников о политиках и процедурах ИБ, проводить регулярные проверки и аудиты с целью выявления нарушений и недостатков, а также поощрять активное содействие сотрудников в обнаружении и предотвращении инцидентов ИБ.

Этот план реагирования на инциденты вступает в силу с момента его утверждения руководителем компании ООО "ABC".

Руководитель компании: _____

(подпись) (Иванов А. Г.)

Ответственный за исполнение: _____

(подпись) (Петров Б. В.)

[Компания ООО "ABC"]

ПРАКТИЧЕСКАЯ РАБОТА ЗАВЕРШЕНА!